AEGIS BANK

Cyber Security Policy

Enterprise AI Decision & Knowledge Platform for Modern Banking

---

Document Information

Field	Details
Document Title	Cyber Security Policy
Document ID	**AB-SEC-003**
Department	Information Security
Version	v1.2
Last Updated	July 24, 2026
Document Owner	Information Security Department
Classification	Confidential
Review Date	July 24, 2027
Approved By	**Sami Khan – Chief Executive Officer (CEO)**

Confidentiality Notice

This Cyber Security Policy defines the security principles, governance framework, and minimum technical and operational controls required to protect Aegis Bank's information assets, technology infrastructure, customers, and business operations from cyber threats.

This document is intended for authorized employees, contractors, vendors, and third parties with approved access to Aegis Bank systems.

Unauthorized disclosure or distribution is prohibited.

Table of Contents

1. Purpose

2. Scope
3. Policy Statement
4. Cyber Security Principles
5. Security Governance
6. Asset Management
7. Identity & Access Management
8. Endpoint Security
9. Network Security
10. Secure Remote Access
11. Security Monitoring
12. Responsibilities
13. Frequently Asked Questions
14. Revision History
15. Document Approval

---

1. Purpose

The purpose of this policy is to establish a comprehensive cybersecurity framework that protects Aegis Bank against cyber threats while ensuring the confidentiality, integrity, and availability of information systems.

Objectives include:

- Protect customer information.
- Secure banking services.
- Reduce cyber risk.
- Meet regulatory requirements.
- Support business continuity.
- Strengthen operational resilience.

---

2. Scope

This policy applies to:

- Employees
- Contractors
- Consultants
- Third-party service providers
- Vendors
- Temporary staff

It covers:

- Data centers
- Cloud infrastructure
- Corporate laptops
- Mobile devices
- Banking applications
- Databases
- APIs
- Internal networks
- Remote access services
- Customer-facing platforms

---

3. Policy Statement

Aegis Bank shall implement layered cybersecurity controls to prevent, detect, respond to, and recover from cyber threats.

Security controls shall be risk-based and aligned with recognized industry practices.

Every employee shares responsibility for protecting the Bank's information assets.

---

4. Cyber Security Principles

The Bank's cybersecurity program is based on:

- Confidentiality
- Integrity
- Availability
- Least Privilege
- Zero Trust
- Defense in Depth
- Secure by Design
- Continuous Monitoring
- Risk-Based Security

---

5. Security Governance

Cybersecurity is governed by the Information Security Department under executive oversight.

Governance activities include:

- Security strategy.
- Risk assessments.
- Security awareness.
- Compliance monitoring.
- Policy management.
- Security reporting.
- Incident oversight.

Major security initiatives shall be reviewed by executive leadership.

---

6. Asset Management

All information assets shall be identified, classified, and protected.

Assets include:

- Servers
- Databases
- Employee laptops
- Network devices
- Cloud resources
- Applications
- APIs
- Backup systems
- Security appliances

Asset owners are responsible for maintaining accurate inventories and ensuring appropriate protection.

---

7. Identity & Access Management

Access to systems shall be granted based on business need.

Requirements include:

- Unique user accounts.
- Strong passwords.
- Mandatory MFA for designated systems.
- Least privilege access.
- Periodic access reviews.
- Immediate revocation of unnecessary access.

Administrative privileges shall be limited to authorized personnel.

---

8. Endpoint Security

All Bank-managed endpoints shall implement approved security controls.

Requirements include:

- Endpoint Detection & Response (EDR).
- Anti-malware protection.
- Disk encryption.
- Secure configuration baselines.
- Automatic security updates.
- Device lock after inactivity.
- USB device restrictions where required.

Unauthorized software installation is prohibited.

---

9. Network Security

The Bank shall protect its networks using layered security controls.

Examples include:

- Firewalls.
- Network segmentation.
- Intrusion Detection Systems (IDS).
- Intrusion Prevention Systems (IPS).
- Secure DNS.
- VPN encryption.
- DDoS protection.
- Network monitoring.

Critical banking systems shall be isolated from public-facing environments where appropriate.

---

10. Secure Remote Access

Remote access is permitted only through approved secure methods.

Requirements include:

- VPN usage.
- Multi-Factor Authentication.
- Managed devices where applicable.
- Encrypted communication.
- Continuous monitoring.
- Session logging.

Public or unsecured devices shall not be used to access sensitive banking systems unless specifically authorized.

---

11. Security Monitoring

The Information Security Team shall continuously monitor the Bank's environment.

Monitoring includes:

- Security logs.
- Authentication events.
- Privileged account activity.
- Endpoint alerts.
- Firewall events.
- Cloud security events.
- Threat intelligence feeds.
- SIEM alerts.

Suspicious activity shall be investigated according to **AB-SEC-004 – Incident Response Plan**.

12. Security Awareness & Training

Cybersecurity is a shared responsibility. All employees shall complete mandatory security awareness training to recognize and respond to cyber threats.

Training topics include:

- Phishing and social engineering.
- Password security.
- Multi-Factor Authentication (MFA).
- Safe email practices.
- Secure remote working.
- Data protection responsibilities.
- Incident reporting procedures.
- Physical security awareness.
- Acceptable use of Bank systems.

Mandatory training shall be completed:

- During employee onboarding.
- Annually thereafter.
- Following significant policy or regulatory changes.

Employees who fail to complete mandatory training may have system access restricted until training requirements are fulfilled.

---

13. Third-Party Security

Third-party vendors and service providers with access to Aegis Bank systems or data must comply with the Bank's cybersecurity requirements.

Minimum requirements include:

- Security risk assessment before onboarding.
- Confidentiality agreements.
- Multi-Factor Authentication where applicable.
- Secure remote access.
- Regular security reviews.
- Compliance with contractual security obligations.

- Timely notification of security incidents affecting Bank information.

High-risk vendors shall undergo enhanced security due diligence.

---

14. Cloud Security Requirements

Cloud-hosted services shall follow approved security standards.

Requirements include:

- Data encryption at rest and in transit.
- Multi-Factor Authentication.
- Role-Based Access Control (RBAC).
- Continuous logging and monitoring.
- Secure API authentication.
- Regular vulnerability assessments.
- Backup and disaster recovery procedures.
- Approved cloud service providers only.

Cloud environments containing customer or confidential banking data shall be subject to enhanced security monitoring.

---

15. Data Protection Controls

Sensitive information shall be protected throughout its lifecycle.

Security controls include:

- Data classification.
- Encryption.
- Access controls.
- Secure backups.
- Data Loss Prevention (DLP) measures.
- Secure disposal of media.

- Audit logging.
- Periodic access reviews.

Customer information shall only be accessed for legitimate business purposes.

---

16. Acceptable Use Requirements

Employees shall use Bank technology resources responsibly.

Users must:

- Use only approved software.
- Lock devices when unattended.
- Report suspicious activity immediately.
- Follow password and MFA requirements.
- Store sensitive information only in approved systems.
- Protect confidential customer information.

Employees must not:

- Install unauthorized software.
- Disable security controls.
- Share user accounts.
- Connect unauthorized devices.
- Access systems without business authorization.
- Use Bank systems for illegal or inappropriate activities.

---

17. Policy Violations

Failure to comply with this Cyber Security Policy may result in:

- Removal of system access.
- Internal investigation.
- Disciplinary action.

- Mandatory retraining.
- Contract termination for third parties.
- Referral to legal or regulatory authorities where applicable.

Intentional security violations shall be treated as serious misconduct.

---

18. Practical Examples

Example 1 – Phishing Email

An employee receives an email requesting banking credentials from an unknown sender.

Correct Action

The employee does not click any links, reports the email to the Information Security Team, and deletes the message after following the Bank's phishing reporting process.

Example 2 – Unauthorized Software

An employee attempts to install an unapproved application on a Bank-managed laptop.

Correct Action

The installation is blocked by endpoint security controls. The employee must request software through the approved IT change process.

Example 3 – Remote Working

An employee works from home and needs access to internal banking systems.

Correct Action

The employee connects using the approved VPN, completes Multi-Factor Authentication, and uses only a Bank-managed encrypted laptop.

Example 4 – Suspicious Login Activity

The Security Operations Center detects repeated failed login attempts against an administrator account.

Correct Action

The account is temporarily protected, security logs are reviewed, additional authentication checks are performed, and the incident is escalated according to the Incident Response Plan.

---

19. Frequently Asked Questions (FAQs)

Q1. Who is responsible for cybersecurity at Aegis Bank?

Cybersecurity is a shared responsibility. Every employee must follow Bank security policies, while the Information Security Department oversees governance and monitoring.

Q2. Can employees install their own software?

No. Only software approved through the Bank's IT processes may be installed on Bank-managed devices.

Q3. Is cybersecurity training mandatory?

Yes. All employees must complete required security awareness training during onboarding and annually thereafter.

Q4. Can I access Bank systems using a personal computer?

Only where explicitly authorized and protected by approved security controls. Bank-managed devices are the preferred standard.

Q5. What should I do if I suspect a cyber incident?

Immediately report the incident to the Information Security Team and follow the procedures defined in the **Incident Response Plan (AB-SEC-004)**.

Q6. Are third-party vendors required to follow this policy?

Yes. Vendors with access to Bank systems or information must comply with applicable cybersecurity requirements and contractual security obligations.

---

20. Related Documents

This policy should be read together with:

- Password Policy (AB-SEC-001)
- Multi-Factor Authentication (MFA) Policy (AB-SEC-002)
- Incident Response Plan (AB-SEC-004)
- Data Classification Policy (AB-SEC-005)
- AI Security Policy (AB-AI-003)
- Disaster Recovery Plan (AB-DR-002)
- Business Continuity Plan (AB-DR-003)

---

21. Revision History

Version	Date	Description	Author
v1.0	January 20, 2026	Initial Release	Information Security Department
v1.1	April 20, 2026	Added Cloud Security, Third-Party Security, and Endpoint Protection Requirements	Information Security Department
v1.2	**July 24, 2026**	**Enhanced Security Awareness Program, Acceptable Use Controls, and Security Monitoring Requirements**	**Information Security Department**

---

22. Document Approval

Field	Details
Document ID	**AB-SEC-003**
Document Title	**Cyber Security Policy**
Department	Information Security

Field	Details
Version	**v1.2**
Classification	**Confidential**
Document Owner	**Information Security Department**
Approved By	**Sami Khan – Chief Executive Officer (CEO)**
Approval Date	**July 24, 2026**
Next Review Date	**July 24, 2027**

Document Control

Attribute	Value
Document Status	Approved
Distribution	Information Security, IT Operations, Infrastructure, Risk Management, Internal Audit, All Employees
Language	English
Storage Location	Aegis Bank Document Management System (DMS)
Retention Period	7 Years
Supersedes	Cyber Security Policy v1.1

End of Document

Aegis Bank
Enterprise AI Decision & Knowledge Platform for Modern Banking

© 2026 Aegis Bank. All Rights Reserved.
